MALWARE INVESTIGATION 2

NAME: ABHISHEK BOMMISETTY

SUMMARY

This is a **PE64** file that is a 64-bit Portable Executable (PE) file which is used for Windows executables.

The size is **1G KB** which is quite small. This could suggest it might be a loader a downloader or heavily packed.

Operating System: Windows Vista/AMD64.

Entropy: 5.35

Compiler: Microsoft Visual C/C++.

HASH: sha256,8D734433GCG6FBDFBAEF23D30ED8BD161245C41F84EC0GE6AACBGD4F88D60F83

md5

G2e60e8263c23ee883183078ed7ddGba Sections

listed:

- .text (Code section).
- .rdata (Read-only initialized data).
- .data (Writable data).
- .pdata (Exception handling functions).
- .rsrc (Resource section).
- .reloc (Relocations)

The **entry point** is set to **00000001400020b0**, which is where the execution of the program begins from.

The entropy graph shows no significant spikes that would suggest suspiciously high or irregular entropy.

STRINGS

powershell Command "C \"C:\\Program Files (x86)\\Microsoft\\Edge\\Application\\msedge.exe\" \"%s\"”

Regisrty keys: Software\Microsoft\Windows\CurrentVersion\Run

URL: https://pastebin.com/raw/NF3fqQ1p Pastebin is commonly used by malware for **C2 communications** or hosting **secondary payloads**.

Strings Indicating File/System Interaction like CreateFileA, ReadFile, WriteFile, CopyFileW, GetFileSize.

XML data indicating requested execution level:
<requestedExecutionLevel level='asInvoker' uiAccess='false' />

This implies that the program will execute with the same privileges as the user running it, not requesting elevated permissions

API Calls: Networking (InternetConnect), file manipulation (CreateFileA). InternetConnect, InternetReadFile, WriteFile: Suggest network communication and file handling.

This suggests the malware might be going to drop an HTML file to deliver a message for ransomware purpose **\Desktop\READMENOW.html**

Registry Manipulation: modifications to registry via **RegSetValueExW** to create a new entry in

HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run

RegOpenKeyExW The malware accesses and modifies the Windows registry to establish ***persistence*** writing and setting the values to run keys to execute malware and modify system configurations or settings for malicious purposes.

Basic Obfuscation Text: **if ((ushort)(sVar2G - 0x41U) < 0x1a) { ... }** and cryptographic functions like CryptHashData, CryptAcquireContextW, CryptCreateHash can be seen in the strings We can also see suspicious strings like encoded HTML

ADVAPI32.DLL

- **CryptAcquireContextW:** Used to acquire a handle to a cryptographic service provider (CSP).
- **CryptHashData:** Used to compute a hash on data. This is critical for data integrity checks or encryption.
- **CryptGetHashParam:** Retrieves data from a cryptographic hash.

DYNAMIC ANALYSYS

Sting of HTML content like"
PGh0bWw+DQo8aGVhZD48L2hlYWQ+DQo8YmGkeSBzdHlsZT0iYmFja2dyb3VuZC1jb2xvcjoglzAwMDAwMDsgY2Gsb3I6I0ZGMzMzMyI+DQoNCjxwcmU+DQoglCBfICAglCAglCAglCAglCAglCAglF8NCiBfKCApICAglCAglCAglCAglCAglCAoICIfDQooXywgfCAglCAglFGfIFGfICAglCAgfCAsXykNCiAglFwnXCAglCAvICBeICBcICAg" are Base64

So, when is decode the Base64 I got the following output in the malware generated a file named READMENOW.html in HTML format this implies and relates to the automatic pop of Microsoft edge saying a message that all the photos have been encrypted asking ransomware by photocrypter for decryption.

Systems and Files Changes:

Files created: READMENOW.html

- **Location:** Found in the \Desktop\ directory based on extracted strings from **win_cma_api_bundle.exe.** The hash of the malware exe and this api exe are same which is **md5 G2e60e8263c23ee883183078ed7ddGba** that the malware modified its name for lower detection in C drive directly.
- **Purpose:** This file appears to have been dropped intentionally and may contain instructions, warnings, or malicious content.
- **Significance:** Association with ransomware or scareware attacks, often serving as a ransom note or alert message.

WPS_DEVICE.XML File

- **Source:** Retrieved through HTTP traffic.
- **Purpose**: Likely linked to network setup or device detection processes.

Files Accessed/Changed:

tskill.exe

- **Location:** Found in the system path. It's a built-in Windows tool used to stop processes by name.
- Purpose: This suggests the malware might be trying to shut down monitoring tools like Process Monitor and Task Manager to stay hidden.

regedit.exe

- **Purpose:** Commands to show attempts to modify the Windows Registry.
- **Reason:** Likely used to maintain **persistence or turn off security settings.**

msedge.exe

- **Location:** Found in **C:\Program Files (x86)\Microsoft\Edge\Application.**
- **Usage:** It's scheduled a task as a hidden PowerShell command to execute using Edge.
- **Why Suspicious**: Malware often misuses trusted programs to bypass detection.

PowerShell Commands

- **Activity:** Hidden PowerShell commands were detected running **Edge** with unusual arguments.
- **Purpose:** The malware is using PowerShell to automate tasks or execute **malicious payloads**.

File Dropping:

- **win_cma_api_bundle.exe** drops a file (READMENOW.html) on the Desktop.

Name	Type	Data
(Default)	REG_SZ	(value not set)
Microsoft Edge ...	REG_SZ	"C:\Users\r00260341\AppData\Local\Microsoft\Ed...
OneDrive	REG_SZ	C:\win_cma_api_bundle.exe
ZoomIt	REG_SZ	C:\Tools\sysinternals\ZoomIt64.exe

C:\Users\r00260341\AppData\Local\Temp Malware sometimes acts as a legitimate software names like Edge to avoid detection in the **AppData\Local folder**, which is commonly used by malware for persistence
By default**, Microsoft OneDrive** adds itself to the Windows **Startup** process during installation. Malware sometimes replaces legitimate entries in the **Run** key to gain persistence.

Registry Changes:

Registry Manipulation

- **Observation:** The path **Software\Microsoft\Windows\CurrentVersion\Run** was referenced.
- **Purpose:** The malware might add an entry here to ensure it runs automatically when the system starts. This is a common technique for maintaining persistence on an infected system.
- **C:\Users\r00260341\AppData\Local\Temp\wct1A40.tmp** has dropped files from malware execution and temporary scripts or executables several **0 KB** files are there in the Temp folder (e.g., 2b802c46-87e6-, b4da6378-).

Network Analysis:

The network traffic shows repeated GET requests to Pastebin URLs. A request to **https://pastebin.com/raw/NF3fqQ1p** indicates that something might have been downloaded, possibly an **encrypted script** or command. This aligns with the behaviour of **win_cma_api_bundle.exe** which likely connects to Pastebin to download and execute malicious scripts.

Numerous amounts of **POST requests** were observed to the paths like **/uuid:4dba2a0a-be77-4fGf-b7d6-Gb57bbf62518/WANCommonInterfaceConfig**

POST requests typically send data to a server, and repeated instances can indicate **data exfiltration** sending the stolen data to a remote server or communication with a command and control (C2) server.

There were multiple failed DNS queries (No such name) targeting internal network systems like **wpad.Home**. These failed DNS can also relate to the network reconnaissance another strong believe for reconnaissance is A GET request for **wps_device.xml** was made.

Defences:

File Obfuscation:

The malware is small (19 KB) with high entropy (5.35), which suggests it's packed or obfuscated to avoid detection. Base64 encoding hides readable content making it harder to spot.

Registry Manipulation:

It adds an entry to the Windows **Run** key at HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run for persistence so this makes sure it runs automatically when the system boots up

Misuse of Trusted Applications: It uses legitimate programs like msedge.exe to appear harmless. Hidden PowerShell commands launch these processes silently.

start powershell -windowstyle hidden -Command "...

Anti-Analysis Techniques:

The malware uses cryptographic functions from ADVAPI32.dll (e.g., CryptAcquireContextW and CryptHashData) to complicate reverse engineering. These functions may encrypt/decrypt data or communication.

User Privilege Management: It runs at the same privilege level as the current user to reduce security alerts: **<requestedExecutionLevel level='asInvoker'>**

Purpose:

The malware's main objectives include encryption, persistence, and remote communication.

Data Encryption (Ransomware): Base64-encoded strings point to a ransom note file named **READMENOW.html**, which states that files (like photos) have been encrypted and a ransom is required.

Persistence: It modifies the Windows Registry Run key to relaunch every time the system starts: C:

\win_cma_api_bundle.exe

File Dropping: It drops key files like: **READMENOW.html** – likely the ransom message. **Temp** files (wctD1C7.tmp, wctD16C.tmp) act as scripts or additional payloads.

C2 Communication: It connects to Pastebin to receive commands or secondary payloads: https://pastebin.com/raw/NF3fqQ1p

Hiding in Trusted Programs:

It runs malicious tasks using trusted software like Microsoft Edge: PowerShell windows style hidden Command **and 'C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe'"**

Recovery and cleanup:

Disconnect from the Network: Isolate the infected computer to stop communication with the malware's C2 server or prevent further encryption. Use **Task Manager** to stop process like**:** **win_cma_api_bundle.exe** or any suspicious PowerShell processes

Remove Persistence Entries: HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run

Delete Temporary Files: Go to **C:\Users\<username>\AppData\Local\Temp** and delete suspicious files like **wctD1C7.tmp, wctD16C.tmp** and any other files which doesn't have any size in the memory Check for duplicates of win_cma_api_bundle.exe and delete them as well.

Block Malicious Network Traffic such as https://pastebin.com/raw/NF3fqQ1p URL and similar Pastebin links on your firewall.

Open Command Prompt as admin and run **sfc /scannow** this will fix corrupted system files

Executive Summary

- The file **win_cma_api_bundle.exe** has been identified as a **malicious program** designed to cause significant harm.
- It uses advanced techniques to:
  - Stay hidden.
  - Run continuously.
  - Deliver its damaging payload.
- **Primary Purpose:**
  - Lock critical files.
  - Disrupt system operations.
  - Demand ransom for recovery.
- **Persistence:**
  - The malware embeds itself deeply into the system.
  - It ensures it relaunches automatically every time the computer starts.
- **Evasion Tactics:**
  - Disguises its actions by misusing trusted programs to avoid detection.
  - Targets and disables monitoring tools to prevent being stopped or analysed.
- **External Communication:**
  - Secretly connects to an external server to receive further instructions or additional files.
  - This behaviour suggests it is part of a **larger coordinated attack.**
- **Impact:**
  - Locks important files.
  - Disrupts the user experience.
  - Puts sensitive data at risk.
- **Conclusion:**
  - The malware poses a **serious, persistent, and dangerous threat**.
  - Immediate action is required to:
    - Remove the malware.
    - Prevent further damage.
    - Secure the system.
  - A thorough cleanup and proactive defines measures are **essential** to restore normal operations and protect against future attacks.

APT Report Analysis

https://www.threatminer.org/reports.php?q=oilrigtargetsamiddleeasterngovernmentandaddsevasiontechniquestooopsie-paloaltonetworksblog.pdf

Report Summary on Attacker Group **OilRig** :

Spear Phishing: Attackers sent a phishing email about "Business Continuity Management Training" that had a harmful attachment.

Malware Used: The updated OopsIE Trojan, now harder to analyze and capable of avoiding virtual machine environments.

Evasion Techniques:

Anti-VM Tests: The malware checks things like fan speed, system temperature, mouse pointer behaviour hard disk, and motherboard details to detect if it's inside a sandbox.

Time Zone Check: It only runs fully if the machine appears to be in a Middle Eastern time zone.

Staying Active (Persistence): It uses scheduled tasks to run itself every **3 minutes.**

Command and Control (C2):

Communicates with its remote servers (C2) using normal web (HTTP) connections.

Uses reversed or scrambled strings in URLs to avoid detection.

Dangerous Domains and IP Addresses: **windowspatch[.]com 172.67.204.68** and **defender-update[.]com** 104.21.58.23

JARM Fingerprint:
273d3ed300003ed1d2fd434000d4161Gb1fbae51eb0d8f708843636dG52c

These domains let the attacker's malware talk to the hacker's servers. Through them commands are received, and stolen data can be sent back to the attacker.

Task 1.2 Geo location

Attacker Group: OilRig,

windowspatch[.]com

ip:"172.67.204.68"

city:"San Francisco"

region:"California"

country:"US"

loc:"37.7621,

-122.3G71"

org:"AS13335 Cloudflare, Inc."

postal:"G4107"

timezone:"America/Los_Angeles"

Open Ports

80 443 2052 2082 2083

2087 8443 8880

Attacker Group:

OilRig, defender-

update[.]com

ip:"104.21.58.23",

city:"San Francisco",

region:"California",

country:"US",

loc:"37.7621,-122.3G7

1",

org:"AS13335 Cloudflare, Inc.",

postal:"G4107",

timezone:"America/Los_Angeles",

Open Ports

80 443 2052 2082 2083

2087 8443 8880

Network Protocol Analysis Protocol Found:

HTTP

Malware Communication: The OopsIE Trojan uses **standard web traffic (HTTP) to talk to its C2 server**, including sending information like the current user's identity **(whoami).**

Hiding Tricks: The malware jumbles text in URLs (like reversing the word **chk into khc** to make it harder for defence tools to recognize it as malicious.

Bad Behavior: The Trojan listens to what the C2 says, then follows the instructions it gets through the HTTP connection

http://www.windowspatch[.]com/khc?<hex_encoded_data>

Persistence and Goals

It stays running by the malware copies itself to a hidden spot in the **user's AppData folder** (WindowsImplantment.exe). It sets up a scheduled task to run every 3 minutes using something like

SchTasks /Create /SC MINUTE /MO 3 /TN "<task_name>" /TR "wscript <path>" /f

A **VBScript** is used to start the malware again if needed.

What is the Motive of the Attackers?

Steal Information: The Trojan gathers data (like results from commands and stolen files) and sends it back to the C2 server.

Spying (Espionage): Targeting government organizations hints that the attackers aim to gather valuable intelligence over a long period.

Targeted Approach: The malware only fully activates if the time zone matches Middle Eastern regions, showing it's carefully aimed at specific victims.

APT Report Analysis

https://threatminer.org/report.php?q=SofacyAttacksMultipleGovernmentEntities_PaloAltoNetworks.pdfCy=2018

Attack Methods: Spear-phishing emails with **malicious attachments** and spoofed sender addresses to look legitimate.

Tools Used

SofacyCarberp: A powerful malware used to gather system information and enable further attacks.

Luckystrike: An open-source tool used to create malicious delivery documents.

Techniques: Embedding malicious **macros** in Excel file and manipulating file attributes and registry entries to ensure the malware works effectively.

Sofacy's attacks targeted **Ministries of Foreign Affairs** across **Europe** and **North America**. The main goal was to:

- Compromise systems.
- Steal sensitive information and intelligence.

Geo Location Domains:

cdnverify[.]net JARM

fingerprint:

2ad2ad0002ad2ad0002ad2ad2ad2ad83c2e51da70Gc877G42cG8b10a5e814a

IP Address :121.40.1GG.127 there are 50 other sites hosted on this server as well

city:"Hangzhou"

region:"Zhejiang"

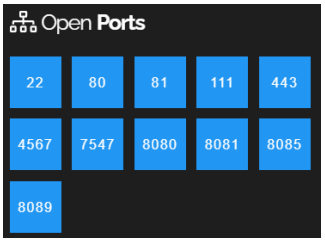
country:"CN"

loc:"30.2936,120.1614"

org:"AS37963 Hangzhou Alibaba Advertising Co.,Ltd."

postal:"310000"

time zone:"Asia/Shanghai"
URL: http://wanwang.aliyun.com



Network Protocol Analysis in the Context of the APT

Sofacy Report Details

Domains: cdnverify[.]net

IPs: Not explicitly mentioned but connected to **spoofed** or **compromised servers**.

Network Protocols Used

SMTP (Simple Mail Transfer Protocol):

Used to send **phishing emails** with fake attachments.

HTTP/HTTPS (Hypertext Transfer Protocol):

Used for **Command-and-Control (C2)** communication between the malware and the attacker's servers. Allows malware traffic to blend with regular web traffic making it harder for security tools to detect the attack.

- **SMTP** enables the initial compromise by targeting users.
- **HTTP/HTTPS** ensures malware can communicate covertly with the attacker's infrastructure for further instructions or data exfiltration.

Persistence and Goals

1. Persistence Techniques

The **Sofacy group** uses advanced techniques to maintain access to compromised systems:

Macros: Delivered through Excel files to drop the **SofacyCarberp** malware.

Registry Keys: Persistence achieved through **UserInitMprLogonScript**. This ensures the malware runs every time the user logs into the system.

DLL Execution: DLL files are executed using **rundll32.exe** which makes it harder for security systems to detect malicious behaviour.

2. Goals and Motivations

The Sofacy group's primary goal is **espionage** specifically to:

- **Steal classified information**: Focused on government agencies like Ministries of Foreign Affairs.
- **Disrupt critical infrastructure**: Though their main focus is espionage, their tools could be used for disruption.
- **Maintain long-term access**: Ensuring control over systems to continue gathering intelligence undetected.

Conclusion:
The Sofacy group is a highly persistent and advanced threat actor. Their attacks focus on stealing intelligence and ensuring they remain hidden on systems for long periods.